C O D E R H O U S E

CIBERSEGURIDAD

Análisis de Phishing y Smishing

Señales de alerta, manipulación y respuesta segura

Unidad 4 | Ejercicio 1

Estudiante	Juan Skobalski
Curso	Ciberseguridad
Tipo de análisis	Ingeniería social
Fecha	3 de noviembre de 2026

Análisis de dos comunicaciones ficticias desde la perspectiva de un analista de seguridad junior.

Introducción

El phishing es una técnica de ingeniería social que intenta lograr que una persona realice voluntariamente una acción perjudicial, como abrir un enlace, entregar credenciales o efectuar un pago. A diferencia de un ataque que explota directamente un defecto de software, el engaño busca aprovechar la confianza, la urgencia y las decisiones tomadas bajo presión.

Este reporte analiza dos casos ficticios: un correo que suplanta a "Soporte Apple" y un SMS que simula provenir de Correos. El objetivo es identificar indicadores técnicos y psicológicos, y transformar el análisis en una recomendación sencilla que pueda aplicar un familiar sin conocimientos especializados.

Alcance y criterio de análisis

El documento se limita a los puntos solicitados en el ejercicio:

- descripción de los dos casos;
- identificación de al menos cuatro señales de alerta en el correo;
- explicación de la técnica psicológica utilizada en el SMS;
- protocolo de respuesta de tres pasos.

No se abren los enlaces indicados ni se intenta comprobar si existen. El análisis se realiza únicamente a partir de la estructura visible de los mensajes, como corresponde a una evaluación segura.

Principio de seguridad: un mensaje sospechoso debe analizarse sin interactuar con sus enlaces, archivos adjuntos ni datos de contacto. La verificación se realiza siempre por un canal independiente.

Resumen de los casos

Caso A - Correo electrónico

Un mensaje de "Soporte Apple" afirma que el Apple ID fue bloqueado y solicita acceder a `http://apple-id-security-check.info` para recuperarlo.

Caso B - Smishing

Un SMS informa que un paquete de Correos fue retenido por una deuda aduanera de 1,20 euros y presenta un enlace acortado para realizar el pago.

Caso A: correo de “Soporte Apple”

El mensaje combina una supuesta autoridad reconocida, la amenaza de perder acceso a una cuenta y una acción inmediata. Ninguno de esos elementos demuestra autenticidad. La evaluación debe centrarse en datos verificables: el dominio, el protocolo, la dirección real del remitente y el procedimiento solicitado.

Señales de alerta identificadas

N.º	Señal	Explicación
1	**Dominio ajeno a Apple**	El dominio registrable es `apple-id-security-check.info`, no `apple.com`. Incluir la marca dentro del nombre no demuestra relación con la empresa.
2	**Uso de HTTP**	La URL comienza con `http://`; la comunicación no estaría cifrada. Además, aunque utilizara HTTPS, el candado no probaría que el propietario sea legítimo.
3	**Urgencia y miedo**	La supuesta cuenta bloqueada busca que la víctima actúe antes de detenerse a verificar la situación.
4	**Remitente no verificado**	“Soporte Apple” puede ser solamente el nombre de visualización. El escenario no muestra la dirección real, por lo que no puede confirmarse un dominio oficial.
5	**Recuperación mediante enlace**	Se pide usar un enlace incluido en el propio correo en vez de acceder independientemente a la configuración oficial de la cuenta.

Evaluación del enlace

En la URL analizada, el dominio registrable no pertenece a `apple.com`. Las palabras `apple` e `id` fueron incorporadas para generar familiaridad, pero no convierten al dominio en propiedad de Apple. La extensión `.info` tampoco es maliciosa por sí misma; el problema es la falta de correspondencia con el dominio oficial de la organización suplantada.

Conclusión del Caso A: la combinación de dominio no oficial, HTTP, presión emocional, identidad no comprobada y recuperación mediante un enlace recibido es coherente con un intento de phishing.

Impacto probable del Caso A

Si la víctima siguiera el enlace, una página falsa podría solicitar su Apple ID, contraseña u otros datos de verificación. El atacante intentaría capturar esa información y utilizarla para acceder a la cuenta. Las consecuencias potenciales incluyen pérdida de control, exposición de datos sincronizados y abuso de servicios o medios de pago asociados.

La existencia de varias señales simultáneas es más importante que cualquier indicador aislado. Por ejemplo, HTTP es claramente inseguro, pero un sitio fraudulento también podría utilizar HTTPS. Del mismo modo, un diseño profesional o el logo de Apple no demostrarían legitimidad porque esos elementos visuales pueden copiarse.

Comprobación segura

La respuesta adecuada no consiste en comprobar el enlace sospechoso. El usuario debe cerrar el mensaje y realizar estas verificaciones de forma independiente:

1. abrir manualmente la configuración del dispositivo o escribir la dirección oficial en el navegador;
2. revisar desde allí las notificaciones y el estado de la cuenta;
3. contactar al soporte utilizando datos obtenidos en el sitio o la aplicación oficial, nunca desde el correo recibido.

Nombre visible y dirección real

El nombre “Soporte Apple” es un texto editable por quien envía el mensaje. Para evaluar la procedencia sería necesario inspeccionar la dirección completa situada detrás de ese nombre y, en un análisis profesional, revisar también los encabezados del correo. Como el caso no aporta esa dirección, la conclusión correcta no es inventarla, sino registrar que la identidad del remitente **no puede verificarse** con la información disponible.

Regla práctica: el diseño, el logo y el nombre de visualización son elementos fáciles de copiar. La decisión debe basarse en el dominio real y en una verificación independiente.

Caso B: smishing del paquete retenido

El segundo mensaje utiliza smishing: phishing distribuido mediante SMS. El pretexto combina una situación cotidiana -la recepción de un paquete- con una deuda aduanera pequeña y una instrucción directa de pago mediante un enlace acortado.

Técnicas psicológicas utilizadas

Técnica	Efecto buscado
Urgencia	La palabra “retenido” sugiere que la víctima debe actuar rápidamente para no perder o demorar el paquete.
Miedo a la pérdida	La posibilidad de no recibir una compra crea una consecuencia concreta y cercana.
Contexto cotidiano	Muchas personas esperan entregas, por lo que el mensaje puede parecer plausible incluso si se envía masivamente.
Baja fricción	El pago de 1,20 euros parece demasiado pequeño para justificar una investigación y favorece una decisión automática.
Ocultamiento del destino	El enlace acortado impide reconocer el dominio real antes de abrirlo.

¿Por qué 1,20 euros resulta efectivo?

La cantidad pequeña reduce la percepción de riesgo. Una víctima puede pensar que pagar cuesta menos tiempo que comprobar el reclamo y que la posible pérdida económica es mínima. Sin embargo, el pago puede ser solamente el pretexto: la página podría intentar obtener datos personales, información de una tarjeta o credenciales.

El atacante no necesita conocer si la persona realmente espera un paquete. Al enviar el mensaje a muchas personas, aumenta la probabilidad de coincidir con alguien que sí realizó una compra reciente. Esa coincidencia hace que el pretexto parezca personalizado aunque no lo sea.

Conclusión del Caso B: la eficacia no depende del importe, sino de combinar urgencia, plausibilidad y una acción de bajo costo aparente.

Protocolo de respuesta para un familiar

La recomendación debe ser breve, recordable y aplicable sin herramientas técnicas. Se proponen tres pasos:

1. Detenerse y no interactuar

No abrir el enlace, no responder, no descargar archivos y no ingresar información. Hacer una pausa corta reduce el efecto de la urgencia y evita que el atacante controle el canal de decisión.

2. Verificar por un canal independiente

Abrir manualmente la aplicación o escribir la dirección oficial en el navegador. Si fuera necesario llamar, utilizar un número obtenido fuera del mensaje, por ejemplo desde el sitio oficial o el reverso de una tarjeta. No usar los enlaces ni teléfonos proporcionados por la comunicación sospechosa.

3. Reportar y protegerse

Marcar el mensaje como phishing o spam, bloquear al remitente y eliminarlo. Si ya se ingresaron datos, cambiar inmediatamente la contraseña desde el sitio oficial, cerrar las sesiones abiertas y activar MFA. Si se proporcionó información de pago, contactar al banco para bloquear o vigilar el medio afectado.

Hacer	No hacer
Acceder por la aplicación o dirección oficial.	Abrir el enlace recibido para “comprobar” si funciona.
Consultar por un teléfono obtenido independientemente.	Llamar al número incluido en el mensaje sospechoso.
Reportar, bloquear y conservar la calma.	Responder, discutir con el remitente o reenviar el enlace.

Conclusión

Los dos casos explotan emociones antes que vulnerabilidades técnicas. En el correo, la revisión del dominio, el protocolo y la identidad del remitente permite detectar la suplantación. En el SMS, la urgencia, la expectativa de recibir un paquete y el pago pequeño disminuyen la resistencia de la víctima.

La defensa más efectiva es interrumpir el recorrido propuesto por el atacante. No se debe utilizar el enlace recibido para verificar el propio mensaje. La comprobación debe comenzar de nuevo mediante una aplicación, un sitio o un teléfono oficial obtenido por separado.